

Informe sobre Business Continuity Management (BCM) y Ciber-Resiliencia

Enfoque en indicadores nacionales para España con comparación internacional (≥2024)

1. Resumen ejecutivo

Desde 2024, la gestión de la continuidad de negocio ha dejado de ser el primo aburrido de la ciberseguridad para convertirse en coprotagonista: reguladores, índices internacionales y estudios académicos convergen en un mensaje incómodo pero claro: **la ciber-resiliencia nacional ya no se mide sólo por “cuántos firewalls tengo”, sino por “cuánto aguanto y cómo me levanto”**.

A grandes rasgos:

- Convergencia BCM–ciberseguridad–resiliencia operativa. La literatura reciente y los informes industriales muestran que los programas de BCP/BCM con mayor madurez reducen de forma significativa el tiempo de respuesta, las pérdidas económicas y el downtime tras ciberataques; en un estudio de 2025 sobre entidades financieras, un incremento del 10% en madurez BCP se asocia con caídas de ~17–22% en tiempos de respuesta, pérdidas y tiempo de interrupción tras incidentes ciber.¹
- Regulación como motor de métricas. NIS2 y DORA exigen explícitamente planes de continuidad, pruebas periódicas, objetivos de recuperación y reporting estructurado de incidentes para operadores de servicios esenciales y entidades financieras en la UE. El ENS 2022 en España refuerza controles de “continuidad del servicio” (análisis de impacto, plan de continuidad, pruebas periódicas y medios alternativos).²³⁴⁵⁶⁷⁸
- Giro hacia indicadores nacionales de ciber-resiliencia. El Global Cybersecurity Index 2024 (ITU) pasa de ranking a sistema por tiers e insiste en que los países integren métricas de ciberseguridad en su planificación nacional. Paralelamente, se proponen marcos de National Cyber Resilience Index (NCRI) que combinan gobernanza, capacidades técnicas, capital humano y colaboración, con indicadores como MTTD/MTTR nacionales, % de infraestructuras críticas certificadas, número de profesionales por millón de habitantes, etc..⁹¹⁰
- España entra en la “primera división” de la ciber-resiliencia global.
Tier 1 (países “role-modelling”, score 95–100) en el GCI 2024.¹⁰
15.^ª posición mundial en el National Cyber Security Index (89,17 puntos).¹¹¹²
Estrategia Nacional de Ciberseguridad 2019 + Plan Nacional de Ciberseguridad 2022, que anuncia un “sistema nacional integrado de indicadores de ciberseguridad”.¹³¹⁴¹⁵
En 2023, el CCN-CERT gestionó 107.777 incidentes, INCIBE-CERT 83.517 y el ESDF-CERT 1.480, según el Informe Anual de Seguridad Nacional 2023.¹⁶¹⁷
- El hueco: indicadores de continuidad y resiliencia a nivel país. España mide muy bien “amenazas e incidentes”, pero todavía de forma fragmentaria la resiliencia funcional: tiempo medio de recuperación de servicios esenciales, cobertura nacional de planes de continuidad, porcentaje de OSE con ejercicios coordinados, etc. Esto la alinea con la crítica del BIS al sector financiero global: abundan los indicadores de cumplimiento; escasean los de resiliencia prospectiva.¹⁸
- Tier 1 (países “role-modelling”, score 95–100) en el GCI 2024.¹⁰
- 15.^ª posición mundial en el National Cyber Security Index (89,17 puntos).¹¹¹²
- Estrategia Nacional de Ciberseguridad 2019 + Plan Nacional de Ciberseguridad 2022, que anuncia un “sistema nacional integrado de indicadores de ciberseguridad”.¹³¹⁴¹⁵
- En 2023, el CCN-CERT gestionó 107.777 incidentes, INCIBE-CERT 83.517 y el ESDF-CERT 1.480, según el Informe Anual de Seguridad Nacional 2023.¹⁶¹⁷

Este informe propone:

1. Un mapa de tendencias internacionales en BCM aplicado a ciber-riesgo desde 2024.
2. Una lectura comparativa de los principales índices globales (GCI, NCSI, índices compuestos de “cyber safety”).
3. Un esquema de indicadores nacionales de BCM/ciber-resiliencia para España, coherente con ENCS 2019, ENS 2022, NIS2 y DORA.
4. Un banco de preguntas de encuesta, con posibles respuestas en clave amable y ligeramente irónica, orientado a capturar la madurez de continuidad y resiliencia a nivel territorio/sector.

2. Contexto: de la continuidad corporativa a la resiliencia país

Históricamente, el BCM nació con un foco muy empresarial: incendios, huelgas, desastres naturales. Los ciberataques se veían como un asunto del CISO y su SOC. La evidencia reciente apunta a un cambio claro:

- Una revisión de literatura sobre BCM y ciber-resiliencia concluye que BCM y Enterprise Risk Management son componentes críticos de la ciber-resiliencia y que la capacidad de responder, recuperarse y evitar crisis depende de marcos integrados, no sólo de controles técnicos.¹⁹
- Estudios empíricos en el sector financiero prueban que la madurez en BCP es uno de los determinantes más fuertes de la ciber-resiliencia, por encima incluso de cierta automatización basada en IA, cuando se mide en términos de reducción de pérdidas, downtime y tiempos de respuesta.¹
- El campo de BCM está viviendo una “segunda ola”: análisis bibliométricos recientes destacan como tendencias emergentes la integración con sistemas de gestión (ISO 9001, ISO 27001, ISO 22301), la resiliencia operativa y la gestión de la complejidad y la incertidumbre.²⁰²¹²²²³

Al trasladar esto al plano nacional, el debate se desplaza de “¿tengo un plan de continuidad por empresa?” a “¿es capaz el país de mantener servicios esenciales y funciones críticas ante ciberincidentes sistémicos, fallos de proveedores cloud, o ataques coordinados a OT?”.

3. Tendencias globales (≥2024) en BCM para la gestión eficaz del riesgo ciber

3.1. Convergencia BCM – ciber-resiliencia – resiliencia operativa

Los últimos informes de DRI, BCI, WEF y ENISA muestran una convergencia clara:

- El BCI – A Year in the World of Resilience 2024 indica que la alta dirección toma ya un papel estratégico en continuidad (56,8%), ciber-resiliencia (55,1%) y resiliencia operativa (48,7%), y que se espera un aumento de inversión en 2025 especialmente en ciber-resiliencia y resiliencia operativa.²⁴²⁵
- El Global Cybersecurity Outlook 2024 del WEF subraya que existe una brecha estructural en capacidades de ciber-resiliencia entre organizaciones y países, y que los enfoques deben pasar de la defensa perimetral a la “capacidad de absorber y recuperarse” de incidentes.²⁶²⁷
- El BIS, en Cyber resilience: Range of practices, constata que muchos supervisores financieros empiezan a evaluar explícitamente prácticas de continuidad y disponibilidad (BCM, pruebas de fallo, segregación de backups), pero que aún hay pocos indicadores adelantados de resiliencia sistemáticamente usados.¹⁸

Traducción para métricas: los indicadores puramente “de seguridad” (nº de vulnerabilidades, % de sistemas parcheados) ya no bastan. Se buscan métricas que conecten:

- Capacidades (existencia de BCP, pruebas, backups segregados).
- Rendimiento (MTTD, MTTR, cumplimiento de RTO/RPO, tiempo medio de recuperación de servicios críticos).
- Impacto (pérdidas económicas, tiempo de interrupción de funciones esenciales, impacto en ciudadanos/empresas).

3.2. Regulación como palanca de continuidad y métricas

NIS2

NIS2 introduce obligaciones detalladas de gestión de riesgos y continuidad para entidades esenciales e importantes en la UE, incluyendo:

- Gestión de riesgos e incidentes, con registro interno, plazos estrictos de notificación (24 h para aviso inicial, 72 h para informe detallado, 1 mes para informe final).⁵²
- Continuidad de negocio: exigencia de planes de continuidad y recuperación, con definición de funciones críticas, objetivos de recuperación y pruebas periódicas de dichos planes.²⁸²⁵
- Cadena de suministro y evaluación sistemática de proveedores críticos, incluyendo su situación de continuidad.²⁹²

Esto empuja a medir, como mínimo, a nivel organización y sector:

- % de servicios esenciales cubiertos por BCP probado.
- Tiempos medios de restauración vs. RTO comprometidos.
- Cobertura de continuidad en proveedores clave.

DORA

DORA, plenamente aplicable desde enero de 2025, lleva esta lógica al extremo en el sector financiero europeo:

- Exige un marco de gestión del riesgo TIC que cubra clasificación de funciones críticas, inventario de activos y escenarios de disrupción severos.³³⁰³¹⁸
- Obliga a disponer de planes de continuidad y de recuperación TIC, con backups segregados, al menos pruebas anuales y re-pruebas tras cambios relevantes.³
- Refuerza la supervisión de proveedores TIC críticos (CTPPs), que deberán demostrar capacidad de resiliencia y continuidad a nivel europeo.³¹⁸³

Implicación nacional: aunque DORA es sectorial, genera datos estructurados sobre BC y resiliencia (ejercicios realizados, resultados de pruebas, tiempos de recuperación, fallos en contingencias) que, agregados, pueden alimentar indicadores país.

ENS 2022 y continuidad en el sector público español

El Real Decreto 311/2022, que actualiza el ENS, incorpora explícitamente:

- Requisito de “continuidad de la actividad” como uno de los requisitos mínimos de seguridad (art. 11.6.n).⁴
- Obligación de vigilancia continua y “evaluación permanente del estado de la seguridad de los activos” para medir su evolución y detectar deficiencias.⁴
- En el desarrollo técnico se especifican controles de análisis de impacto, plan de continuidad, pruebas periódicas y medios alternativos.⁶⁷

Esto da pie, de facto, a:

- KPIs de cumplimiento ENS en continuidad (porcentaje de sistemas con BIA, BCP, ejercicios anuales, resultados de auditorías).
- Indicadores agregados a nivel administración general del Estado, CCAA, EELL, etc.

3.3. Digitalización del BCM: IA, datos y cultura

Tendencias 2024–2025 en BCM destacan:

- Uso creciente de IA para monitorización de riesgos y escenarios, integrando feeds de amenazas, clima, conflictos, etc., en motores que alimentan planes de continuidad dinámicos.³²³³¹
- Extensión de BCM a cadenas de suministro y entornos OT, especialmente tras el auge de ataques a infraestructuras críticas y OT reportados por ENISA y otros.³⁴³⁵³⁶
- Valoración de la “resiliencia como cultura”: formar a toda la organización, hacer ejercicios de crisis multidisciplinares y entrenar operaciones en “modo degradado”.³³³²²⁶

Desde el punto de vista de indicadores, esto se traduce en:

- Métricas de cobertura de ejercicios (nº de simulacros al año, participación por área, cobertura de escenarios ciber, OT, terceros).
- Indicadores humanos: porcentaje de personal crítico formado, resultados de ejercicios, tasa de éxito en simulaciones de phishing y crisis.³⁷³⁸
- Integración de métricas de continuidad en cuadros de mando de dirección (nº de días en que el país/sector ha operado en “modo degradado” por incidentes TIC, número de servicios con plan probado de trabajo manual alternativo, etc.).

4. Índices y marcos internacionales de indicadores nacionales de ciber-resiliencia

4.1. Global Cybersecurity Index 2024 (ITU)

El GCI 2024 mide compromisos nacionales en cinco pilares: legal, técnico, organizativo, desarrollo de capacidades y cooperación. Cambios clave:¹

- Pasa de ranking a un modelo por tiers (T1–T5). Tier 1 agrupa países con puntuaciones 95–100 y fuerte compromiso transversal.¹⁰
- Incorpora como indicadores:
 - Existencia de Estrategia Nacional de Ciberseguridad con plan de acción e indicadores.¹⁰
 - Regulación de infraestructuras críticas y capacidad de respuesta (CIRTs/CSIRTs).¹⁰
 - Campañas de concienciación, formación, currículos, acuerdos internacionales, etc..¹⁰
- Existencia de Estrategia Nacional de Ciberseguridad con plan de acción e indicadores.¹⁰
- Regulación de infraestructuras críticas y capacidad de respuesta (CIRTs/CSIRTs).¹⁰
- Campañas de concienciación, formación, currículos, acuerdos internacionales, etc..¹⁰

España está clasificada en **Tier 1 – Role-modelling** (score 95–100), dentro del grupo de países europeos más avanzados.²

² https://www.itu.int/en/ITU-D/Cybersecurity/Documents/GCIv5/2401416_1b_Global-Cybersecurity-Index-E.pdf

² https://www.itu.int/en/ITU-D/Cybersecurity/Documents/GCIv5/2401416_1b_Global-Cybersecurity-Index-E.pdf

² <https://ncsi.ega.ee/ncsi-index/>

² <https://e-estonia.com/the-national-cyber-security-index-ranks-160-countries-cyber-security-status/>

² <https://www.mixmode.ai/blog/global-cybercrime-report-2024-which-countries-face-the-highest-risk>

² <https://betanews.com/article/highest-and-lowest-cyber-risk-countries-revealed/>

² <https://eudoxuspress.com/index.php/pub/article/download/4030/2926/8022>

² https://www.enisa.europa.eu/sites/default/files/ncss-map/strategies/reports/EE_NCSS_2024_en.pdf

² <https://www.publicsafety.gc.ca/cnt/rsrscs/pblctns/ntnl-cbr-scrtr-strtg-2025/index-en.aspx>

² <https://eudoxuspress.com/index.php/pub/article/download/4030/2926/8022>

² https://www.ciat.org/Biblioteca/DocumentosTecnicos/Espanol/2024_Guia_plan_Continuidad_CIAT_GIZ.pdf

4.2. National Cyber Security Index (NCSI)

El NCSI, desarrollado por la e-Governance Academy de Estonia, evalúa capacidades de ciberseguridad nacionales en base a **medidas implementadas**, no incidentes sufridos.³⁴

- Dimensiones: política de ciberseguridad, lucha contra el crimen, protección de servicios esenciales, educación y cultura de ciberseguridad, ciberdefensa, etc..¹¹¹²
- Cada indicador evalúa si el país tiene:
Estrategia vigente.
Marcos de supervisión.
Requisitos obligatorios para operadores esenciales y sector público (ISO 27001, ENS, etc.).
CSIRT nacional con mandato claro y capacidades, entre otros.¹²¹¹
- Estrategia vigente.
- Marcos de supervisión.
- Requisitos obligatorios para operadores esenciales y sector público (ISO 27001, ENS, etc.).
- CSIRT nacional con mandato claro y capacidades, entre otros.¹²¹¹

España:

- Puntuación NCSI: 89,17 / 100, posición 15.^a mundial (versión 2025 del índice).¹¹¹²
- Anteriormente, ya se situaba por encima de 88 puntos y 10.^a posición, lo que refleja una posición consolidada.⁴⁰

² https://www.scirp.org/pdf/oalibj_2023042015461836.pdf

² <https://onlinelibrary.wiley.com/doi/abs/10.1111/1468-5973.12501>

² <https://eudoxuspress.com/index.php/pub/article/download/4030/2926/8022>

4.3. Índices compuestos de “Cyber Safety / Cyber Resilience”

Informes recientes (ej. *Global Cybercrime Report 2024*) combinan NCSI, GCI, índices de exposición y un *Cyber Resilience Index* propio para generar un “Final Cyber Safety Score” por país.⁵⁶

- Países nórdicos y algunos anglosajones (Finlandia, Noruega, Dinamarca, Australia, Reino Unido, Canadá) aparecen como los de menor riesgo, con puntuaciones finales > 88, combinando alta preparación técnica, marco legal robusto y madurez en resiliencia.⁴²⁴¹
- Estos índices componen, de forma explícita, las dimensiones que veremos luego en el NCRI académico: gobernanza, capacidades técnicas, exposición y resiliencia.⁹⁴¹

Aunque no publican para todos los países todos los sub-scores, sí orientan:

- Qué familias de indicadores se consideran clave a nivel país.
- Dónde se ubica el listón de los “mejores de la clase” que suele interesar a reguladores y estrategias.

4.4. Propuestas académicas: National Cyber Resilience Index (NCRI)

Un trabajo académico reciente propone un **NCRI** que va un paso más allá de los índices de ciberseguridad clásicos:⁷

- Dimensiones:
 - Gobernanza: nº y calidad de leyes, estrategias, tiempo de respuesta del CERT nacional, % presupuesto público dedicado a ciber.9
 - Capacidades técnicas: MTDD y MTTR promedio nacional, % de infraestructuras críticas certificadas (ISO 27001, ISO 22301), adopción de estándares y redundancias.9
 - Capital humano: profesionales certificados por millón de habitantes, programas formativos, campañas de concienciación.9
 - Colaboración: acuerdos internacionales, asociaciones público-privadas, ejercicios nacionales de ciber crisis.9
 - Metodología:
 - Selección de indicadores cuantificables y comparables.
 - Normalización, ponderación transparente y benchmarking frente a índices existentes (GCI, NCSI).
 - Uso de balanced scorecard para proporcionar una visión equilibrada.9
 - Gobernanza: nº y calidad de leyes, estrategias, tiempo de respuesta del CERT nacional, % presupuesto público dedicado a ciber.9
 - Capacidades técnicas: MTDD y MTTR promedio nacional, % de infraestructuras críticas certificadas (ISO 27001, ISO 22301), adopción de estándares y redundancias.9
 - Capital humano: profesionales certificados por millón de habitantes, programas formativos, campañas de concienciación.9
 - Colaboración: acuerdos internacionales, asociaciones público-privadas, ejercicios nacionales de ciber crisis.9
 - Selección de indicadores cuantificables y comparables.
 - Normalización, ponderación transparente y benchmarking frente a índices existentes (GCI, NCSI).
 - Uso de balanced scorecard para proporcionar una visión equilibrada.9
- Lo interesante para España no es tanto el valor absoluto (el índice está en propuesta), sino:
- Que incluye explícitamente indicadores de rendimiento (MTDD/MTTR nacionales, frecuencia de ejercicios, etc.) y no sólo de existencia de marcos.
 - Que conecta bien con la filosofía ENS (evaluación continua y mejora) y con los requerimientos de NIS2/DORA.

5. Posición de España en el panorama internacional

5.1. Estrategia, planes y marco normativo

- Estrategia Nacional de Ciberseguridad 2019 (ENCS 2019).
Actualiza la estrategia de 2013 y se alinea con la Estrategia de Seguridad Nacional.⁴³⁴⁴⁴⁵
Define como objetivo específico la seguridad y resiliencia de las redes y sistemas del sector público y servicios esenciales, y compromete al sistema público a elaborar un informe anual de evaluación del grado de ejecución.¹⁵¹³
Incluye la creación de mecanismos e indicadores agregados de riesgo adecuados a las condiciones de ciberseguridad y a la protección de infraestructuras y servicios esenciales.¹³
- Plan Nacional de Ciberseguridad (PNC) 2022.
Aprobado por el Consejo de Ministros el 29 de marzo de 2022; contempla cerca de 150 iniciativas para tres años.¹⁵
Entre sus líneas se incluye desarrollar un sistema nacional integrado de indicadores de ciberseguridad, crear una plataforma nacional de notificación y seguimiento de ciberincidentes y reforzar la ciberseguridad de pymes y autónomos.¹⁴⁴⁶
- ENS 2022 (RD 311/2022).
Reafirma la necesidad de plena implantación del ENS como medida clave del primer objetivo de la ENCS 2019.¹⁵
Establece principios de “vigilancia continua” y “reevaluación periódica” del estado de la seguridad.⁴
Incorpora y detalla requisitos de continuidad del servicio: análisis de impacto, planes de continuidad, pruebas y medios alternativos.⁷⁶⁴
- Refuerzo normativo 2025.
El anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad para transponer NIS2 crea la figura del Centro Nacional de Ciberseguridad y fija un régimen sancionador reforzado.⁴⁷
La Orden PJC/448/2025 se presenta como refuerzo del PNC, aprobando nuevas actuaciones en materia de ciberseguridad y aumentando la inversión total hasta alrededor de 1.157 M€. ⁴⁷
Estrategias sectoriales específicas, como la Estrategia de Ciberseguridad del SNS 2025-2028, incluyen objetivos de garantizar la continuidad asistencial y la disponibilidad de datos sanitarios frente a incidentes, alineados con ENS y NIS2.⁴⁷

- Actualiza la estrategia de 2013 y se alinea con la Estrategia de Seguridad Nacional.434445
- Define como objetivo específico la seguridad y resiliencia de las redes y sistemas del sector público y servicios esenciales, y compromete al sistema público a elaborar un informe anual de evaluación del grado de ejecución.1513
- Incluye la creación de mecanismos e indicadores agregados de riesgo adecuados a las condiciones de ciberseguridad y a la protección de infraestructuras y servicios esenciales.13
- Aprobado por el Consejo de Ministros el 29 de marzo de 2022; contempla cerca de 150 iniciativas para tres años.15
- Entre sus líneas se incluye desarrollar un sistema nacional integrado de indicadores de ciberseguridad, crear una plataforma nacional de notificación y seguimiento de ciberincidentes y reforzar la ciberseguridad de pymes y autónomos.1446
- Reafirma la necesidad de plena implantación del ENS como medida clave del primer objetivo de la ENCS 2019.15
- Establece principios de “vigilancia continua” y “reevaluación periódica” del estado de la seguridad.4
- Incorpora y detalla requisitos de continuidad del servicio: análisis de impacto, planes de continuidad, pruebas y medios alternativos.764
- El anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad para transponer NIS2 crea la figura del Centro Nacional de Ciberseguridad y fija un régimen sancionador reforzado.47
- La Orden PJC/448/2025 se presenta como refuerzo del PNC, aprobando nuevas actuaciones en materia de ciberseguridad y aumentando la inversión total hasta alrededor de 1.157 M€.47
- Estrategias sectoriales específicas, como la Estrategia de Ciberseguridad del SNS 2025-2028, incluyen objetivos de garantizar la continuidad asistencial y la disponibilidad de datos sanitarios frente a incidentes, alineados con ENS y NIS2.47

5.2. Capacidades y resultados medidos

Algunos datos de “salud nacional” de ciber-resiliencia:

- Rangos internacionales.
Tier 1 (score 95–100) en el GCI 2024.10
15.^a posición en NCSI (89,17 puntos; muy por encima de la media global).1211
- Gestión de incidentes.
En 2023, el CCN-CERT gestionó 107.777 ciberincidentes, INCIBE-CERT 83.517 y el ESDF-CERT 1.480, según el Informe Anual de Seguridad Nacional 2023.1716
INCIBE detalla que de los 83.517 incidentes: >58.000 afectaron a ciudadanía, >22.000 a empresas, 237 a operadores esenciales y críticos y 1.673 a universidades, salud y otras entidades RedIRIS.48495051
Se detectaron 183.077 sistemas vulnerables y más de 7.000 sitios con contenido abusivo; 3 de cada 10 incidentes gestionados fueron fraude online.495017
- Análisis de amenazas y tendencias.
El CCN-CERT publica anualmente su informe de Ciberamenazas y Tendencias (IA-04/24 para edición 2024), que destaca el papel del ciberespionaje, hacktivismo (especialmente DDoS a administraciones públicas) y cibercrimen tipo ransomware, así como el uso creciente de IA generativa en ataques.5253545556
- Tier 1 (score 95–100) en el GCI 2024.10
- 15.^a posición en NCSI (89,17 puntos; muy por encima de la media global).1211
- En 2023, el CCN-CERT gestionó 107.777 ciberincidentes, INCIBE-CERT 83.517 y el ESDF-CERT 1.480, según el Informe Anual de Seguridad Nacional 2023.1716
- INCIBE detalla que de los 83.517 incidentes: >58.000 afectaron a ciudadanía, >22.000 a empresas, 237 a operadores esenciales y críticos y 1.673 a universidades, salud y otras entidades RedIRIS.48495051
- Se detectaron 183.077 sistemas vulnerables y más de 7.000 sitios con contenido abusivo; 3 de cada 10 incidentes gestionados fueron fraude online.495017
- El CCN-CERT publica anualmente su informe de Ciberamenazas y Tendencias (IA-04/24 para edición 2024), que destaca el papel del ciberespionaje, hacktivismo (especialmente DDoS a administraciones públicas) y cibercrimen tipo ransomware, así como el uso creciente de IA generativa en ataques.5253545556

Estos datos son oro para construir indicadores nacionales, pero hoy se usan sobre todo en clave descriptiva (volumen, tipo de amenaza, evolución) más que en clave de **objetivos de resiliencia** (p. ej., “reducir el MTTR agregado de incidentes críticos un X % en tres años”).

5.3. Lo que falta medir (y que otros países ya empiezan a medir)

Comparando con las propuestas NCRI y con estrategias como las de Estonia o Canadá, se aprecian algunas brechas:⁸⁹¹⁰

- Falta un conjunto público y estable de KPIs nacionales de resiliencia, más allá de rankings (GCI, NCSI) y volúmenes de incidentes.
- Poca visibilidad de indicadores como:
 - Tiempo medio de recuperación de servicios públicos críticos tras incidentes TIC.
 - Cobertura de BCP/BCM en operadores esenciales y administración (nº y % con planes probados).
 - Frecuencia de ejercicios nacionales de ciber crisis y continuidad multinivel (Estado-CCAA-sector privado) y su evaluación.
- Escasa explotación pública de métricas derivadas de ENS (grado de conformidad en controles de continuidad, nivel de madurez) a nivel agregado.⁶⁷⁴
- Tiempo medio de recuperación de servicios públicos críticos tras incidentes TIC.
- Cobertura de BCP/BCM en operadores esenciales y administración (nº y % con planes probados).
- Frecuencia de ejercicios nacionales de ciber crisis y continuidad multinivel (Estado-CCAA-sector privado) y su evaluación.

En términos futbolísticos: España juega en Champions en ciberseguridad normativa y de capacidades, pero aún no publica la tabla de “kilómetros recorridos, pases completos y recuperación tras gol en contra” a nivel de continuidad nacional.

6. Propuesta de sistema de indicadores nacionales de BCM y ciber-resiliencia para España

6.1. Principios de diseño

Siguiendo tu línea GQM y la literatura sobre NCRI:11121314

5. Orientación a objetivos país.
Ejemplo de objetivo estratégico: “Mantener la prestación de servicios esenciales a niveles aceptables ante ciberincidentes graves y fallos de proveedores TIC”.
 6. Capas de indicadores.
Estratégicos (orientados a Gobierno y opinión pública).
Tácticos (ministerios, agencias, reguladores sectoriales).
Operacionales (CERTs, operadores, administraciones).
 7. Dimensiones MECE.
Gobernanza y marco.
Capacidades y preparación.
Rendimiento y impacto.
Ecosistema y cultura.
 8. Fuentes existentes, no utópicas.
GCI, NCSI, ENS, informes CCN-CERT, INCIBE, ENS-auditorías, estadísticas sectoriales (energía, salud, transporte).
 9. Comparabilidad internacional.
Siempre que sea posible, usar indicadores análogos a los de GCI, NCSI, NCRI y marcos BIS/BCBS.1812910
- Ejemplo de objetivo estratégico: “Mantener la prestación de servicios esenciales a niveles aceptables ante ciberincidentes graves y fallos de proveedores TIC”.
 - Estratégicos (orientados a Gobierno y opinión pública).
 - Tácticos (ministerios, agencias, reguladores sectoriales).
 - Operacionales (CERTs, operadores, administraciones).
 - Gobernanza y marco.
 - Capacidades y preparación.
 - Rendimiento y impacto.
 - Ecosistema y cultura.
 - GCI, NCSI, ENS, informes CCN-CERT, INCIBE, ENS-auditorías, estadísticas sectoriales (energía, salud, transporte).

- Siempre que sea posible, usar indicadores análogos a los de GCI, NCSI, NCRI y marcos BIS/BCBS.1812910

6.2. Cuadro sintético de indicadores propuestos

Dimensión	Indicador nacional sugerido	Fuente principal (potencial)	Notas / comparabilidad
Gobernanza	Existencia y vigencia de Estrategia Nacional de Ciberseguridad con plan de acción e indicadores (S/N)	ENCS 2019, PNC131514	Alineado con GCI (pilar organizativo)10
Gobernanza	% de medidas del Plan Nacional de Ciberseguridad ejecutadas o en curso	Seguimiento PNC1547	Indicador de implementación real, no sólo de diseño
Gobernanza	Posición y puntuación en GCI y NCSI	ITU GCI, NCSI101211	Benchmark externo consolidado
Capacidades	Nº de CERT/CSIRT nacionales (gobierno, ciudadanos/empresas, defensa) con mandato operativo definido	CCN-CERT, INCIBE-CERT, ESDF-CERT1649	Se puede extender a CSIRT sectoriales (salud, energía...)
Capacidades	% de operadores de servicios esenciales con BCP/BCM alineado con ISO 22301 o equivalente y probado al menos anual	Supervisores sectoriales, transposición NIS2255960	Refleja cumplimiento de NIS2 y buenas prácticas ISO 22301
Capacidades	% de sistemas de información del sector público con controles ENS de continuidad (BIA, BCP, pruebas, medios alternativos) implantados	Auditorías ENS476	Requiere explotación agregada de datos ENS
Rendimiento	Nº de ciberincidentes significativos por 100.000 habitantes y por sector (ciudadanía, empresas, operadores esenciales, sector público)	INCIBE-CERT, CCN-CERT, ESDF-CERT164950	Conviene estandarizar definiciones de "significativo"

Rendimiento	Tiempo medio nacional de recuperación de servicios esenciales tras incidentes TIC (MTTR agregado estimado)	Informes de operadores esenciales, reguladores, CCN-CERT164918	Puede empezar con recolocación por rangos ($\leq 4h$, 4–24h, $>24h$)
Rendimiento	% de incidentes críticos en operadores esenciales que requieren activar planes de continuidad (uso real del BCP)	Operadores esenciales, NIS225	Mide uso efectivo de BCM, no sólo su existencia
Impacto	Estimación anual de pérdidas económicas directas por ciberincidentes (% del PIB)	IASN, estudios económicos complementarios1627	Puede comenzar con bandas agregadas
Impacto	Nº de días/año en los que servicios clave (salud, energía, transporte, administración electrónica) operan en modo degradado por incidentes TIC	Informes sectoriales, BCP364761	Indicador potente de resiliencia real, pero exige armonizar reporting
Ecosistema	Nº de ejercicios nacionales de ciber crisis y continuidad multi-actor al año, y % de CCAA/sectores participantes	DSN, CCN, INCIBE, CCAA431636	Se puede puntuar por escala (municipal, autonómica, nacional)
Ecosistema	Nº de personas formadas en ciberseguridad y continuidad (ciudadanía, pymes, sector público) / 100.000 habitantes	INCIBE, programas de formación494862	Indicador ya medido parcialmente (117.000 personas formadas en 2023)48

Cultura	% de organizaciones del sector público y operadores esenciales que realizan al menos un ejercicio anual de BCP que incluya escenarios ciber	ENS, NIS2, supervisores247	Alineado con BIS/BCBS y DORA183
----------------	---	----------------------------	---------------------------------

No todo esto es inmediatamente medible hoy, pero buena parte ya se genera —aunque dispersa— en:

- Seguimiento del PNC.
- Auditorías ENS.
- Informes anuales de DSN (IASN).
- Reporting NIS/NIS2 sectorial.
- Memorias de reguladores (CNMV, BdE, DGSFP, CNMC, etc.).

El desafío es más de **gobernanza de datos e integración** que de ausencia de información.

7. Banco de preguntas de encuesta y respuestas sugeridas (tono ameno, pero útil)

A continuación, se propone un conjunto de bloques temáticos de encuesta pensados para capturar la percepción y madurez de continuidad/ciber-resiliencia a nivel nacional/territorial (ministerios, CCAA, grandes operadores, etc.). Se sugiere escala tipo Likert de 4–5 niveles, con formulaciones que inviten a la reflexión (y a la sonrisa resignada).

7.1. Gobernanza y marco de continuidad

P1. En su organización, ¿cómo describiría el grado de integración entre la estrategia de ciberseguridad y la de continuidad de negocio?

- a) “Cada una vive en su universo paralelo; se cruzan sólo en los pasillos (o en los incidentes).”
- b) “Nos coordinamos para las grandes ocasiones (auditorías, regulador, sustos serios).”
- c) “Compartimos objetivos, riesgos y casi las mismas reuniones, pero aún hay silos.”
- d) “Funcionan como un único programa de resiliencia, con gobierno, métricas y reporting comunes.”

P2. Respecto al cumplimiento de ENS/NIS2/DORA en materia de continuidad, su organización se siente...

- a) “En fase de lectura atenta del BOE y subrayado intensivo.”
- b) “Hemos hecho el diagnóstico y tenemos una hoja de ruta en marcha.”
- c) “Cumplimos los mínimos y hacemos pruebas puntuales (cuando el calendario lo permite).”
- d) “Tenemos un modelo maduro, con auditorías regulares, métricas y mejora continua.”

7.2. Planificación y alcance del BCM

P3. ¿Qué porcentaje aproximado de sus procesos/servicios críticos están cubiertos por planes de continuidad formales?

- a) “Menos del 25%: confiamos mucho en la suerte y en el heroísmo del personal.”
- b) “Entre el 25% y el 60%: las joyas de la corona están cubiertas, el resto... en proceso.”
- c) “Entre el 60% y el 90%: casi todo lo que duele tiene un plan, aunque alguno sea vintage.”
- d) “Más del 90%: si algo es crítico, tiene BCP vivo, probado y con dueño claro.”

P4. En esos planes, ¿hasta qué punto se contemplan escenarios específicos de ciberincidentes (ransomware, DDoS, caída de proveedor cloud, fallo masivo de actualización tipo CrowdStrike)?

- a) “Están implícitos: ‘si pasa algo de ordenadores, ya se verá’.”
- b) “Tenemos menciones genéricas a ‘incidentes TIC’ sin bajar mucho al detalle.”
- c) “Hay escenarios tipo, pero todavía no cubren bien dependencias OT/proveedores.”
- d) “Los principales escenarios ciber están modelizados, con acciones concretas y roles definidos.”

7.3. Ejercicios, pruebas y aprendizaje

P5. ¿Con qué frecuencia se realizan pruebas o simulacros de los planes de continuidad (incluyendo escenarios ciber) en su organización?

- a) “Nunca, o sólo cuando la realidad decide organizar su propio simulacro.”
- b) “Esporádicamente (cada 2–3 años) y más por obligación que por convicción.”
- c) “Al menos una vez al año, aunque con alcance limitado.”
- d) “Con una planificación anual estructurada, incluyendo ejercicios conjuntos con otras entidades.”

P6. Tras ejercicios o incidentes reales, ¿qué ocurre con las lecciones aprendidas?

- a) “Se comentan en un par de correos y quedan para la posteridad en una carpeta olvidada.”
- b) “Se elabora un informe, pero las acciones correctivas se diluyen con el tiempo.”
- c) “Se genera un plan de acción con responsables y plazos, aunque el seguimiento es irregular.”
- d) “Las lecciones alimentan un registro central, se priorizan y se cierran con seguimiento ejecutivo.”

7.4. Métricas y reporting

P7. ¿Qué tipo de indicadores de continuidad y ciber-resiliencia se reportan regularmente a la alta dirección?

- a) “Principalmente indicadores de cumplimiento (nº de políticas, auditorías superadas).”
- b) “Se incluyen algunos KPIs técnicos (MTTD, MTTR, nº de incidentes) sin gran conexión de negocio.”
- c) “Se presentan también métricas de impacto (downtime de servicios, pérdidas estimadas, cumplimiento de RTO).”
- d) “Existe un cuadro de mando de resiliencia que integra riesgos, capacidades, rendimiento e impacto, con objetivos anuales.”

P8. ¿Cómo describiría la calidad de los datos usados para estos indicadores?

- a) “Artesanales y con mucho Excel emocional.”
- b) “Aceptables, aunque con lag y alguna inconsistencia entre fuentes.”
- c) “En general fiables, automatizados en buena parte, con validaciones básicas.”
- d) “Automatizados, trazables y auditables; los datos se usan también para analítica avanzada.”

7.5. Ecosistema, proveedores y territorio

P9. Respecto a sus proveedores TIC críticos (incluyendo cloud, telecomunicaciones, OT...), ¿cómo valora su integración en sus propios planes de continuidad?

- a) “Los contratos dicen algo de ‘soporte 24x7’ y confiamos en su buena voluntad.”
- b) “Se les exige un BCP, pero rara vez se revisa o prueba conjuntamente.”
- c) “Participan en algunos ejercicios y existe intercambio básico de información de resiliencia.”
- d) “Están plenamente integrados: BCP alineados, ejercicios conjuntos y métricas compartidas de continuidad.”

P10. Desde la perspectiva de país/territorio, ¿hasta qué punto percibe que existe una coordinación efectiva de continuidad y ciber-resiliencia entre administración, operadores esenciales y sector privado?

- a) “Cada uno juega su propia liga; nos vemos en los comunicados de prensa tras los incidentes.”
- b) “Hay foros y grupos de trabajo, pero la coordinación operativa aún es limitada.”
- c) “Se realizan ejercicios conjuntos y hay canales de intercambio de información más o menos fluidos.”
- d) “Existe un marco claro de coordinación en crisis, con roles definidos, protocolos y ejercicios regulares multi-actor.”

Estas preguntas, adaptadas por sector/territorio, permiten derivar **índices de madurez** (por dimensión) que pueden mapearse directamente a los indicadores propuestos en el apartado anterior.

8. Conclusiones y recomendaciones

10. La continuidad de negocio se ha convertido en el lenguaje común entre ciberseguridad, negocio y reguladores. Estudios empíricos, normas ISO 22301/27001/27035 y marcos de resiliencia lo confirman: la madurez BCM correlaciona con mejor desempeño ante ciberincidentes. Ignorar esto a nivel país sería una excentricidad estratégica.606359191
11. España parte de una posición de fuerza, pero con margen de sofisticación en indicadores. Estar en Tier 1 del GCI y en el top-20 del NCSI significa que el armazón institucional y normativo es sólido. El reto está en bajar al terreno de:111210
MTTR de servicios esenciales.
Cobertura real de BCP (ENS, NIS2, DORA).
Resultados de ejercicios y capacidad de operar en modo degradado.
12. La ventana de oportunidad es ahora.
La actualización del ENS, la transposición de NIS2, la entrada en vigor de DORA y el refuerzo del Plan Nacional de Ciberseguridad crean el contexto perfecto para formalizar un Sistema Nacional de Indicadores de Ciber-Resiliencia y Continuidad.142347154
Si este sistema se diseña alineado con GCI, NCSI y propuestas NCRI, España puede no sólo medir mejor, sino también influir en los estándares internacionales.

13. Recomendaciones concretas de política y comunidad técnica:

Consolidar una “Oficina de Datos de Resiliencia Nacional” bajo el futuro Centro Nacional de Ciberseguridad, con mandato claro de:

Definir y mantener el catálogo oficial de indicadores nacionales.

Integrar datos de ENS, NIS2, DORA, CERTs y reguladores.

Publicar informes periódicos de resiliencia (no sólo de amenazas/incidentes).

Normalizar el reporting de continuidad en operadores esenciales y sector público.

Formularios estándar de incidentes que recojan RTO comprometidos, tiempos reales de restauración, uso de BCP, modo degradado, etc..253

Incorporar estos datos en el IASN y en los informes anuales de ENCS/PNC.161315

Extender la lógica de ENS a la empresa privada crítica.

Aprovechar la actualización ENS y la futura Ley de Ciberseguridad para alinear controles de continuidad (BIA, BCP, pruebas) con NIS2/DORA, y exigir reportes agregables.7234

Impulsar ejercicios nacionales de ciber crisis y continuidad multinivel con métricas claras.

Cada ejercicio debería producir KPIs comparables (tiempos de decisión, de notificación, de restauración, calidad de la coordinación) y alimentar el cuadro nacional.613618

Convertir el banco de preguntas de encuesta en instrumento de diagnóstico periódico.

Aplicado a CCAA, grandes operadores y ministerios, permitiría seguir la evolución de la madurez de BCM/ciber-resiliencia con un coste bajo y una riqueza cualitativa alta.589

14. Narrativa país: de “ciberseguridad avanzada” a “ciber-resiliencia demostrable”.

España ya figura como actor destacado en índices globales. El siguiente paso es poder responder, con datos y no sólo con buenas intenciones, a preguntas como:271210

“¿Cuánto tarda el país en recuperar sus servicios esenciales tras un ciberincidente grave?”

“¿Qué porcentaje de nuestra economía depende de proveedores TIC críticos cuya continuidad hemos probado en serio?”

“¿Cuántas veces al año ensayamos, como país, una gran interrupción digital?”

- MTTR de servicios esenciales.
- Cobertura real de BCP (ENS, NIS2, DORA).
- Resultados de ejercicios y capacidad de operar en modo degradado.
- La actualización del ENS, la transposición de NIS2, la entrada en vigor de DORA y el refuerzo del Plan Nacional de Ciberseguridad crean el contexto perfecto para formalizar un Sistema Nacional de Indicadores de Ciber-Resiliencia y Continuidad.142347154
- Si este sistema se diseña alineado con GCI, NCSI y propuestas NCRI, España puede no sólo medir mejor, sino también influir en los estándares internacionales.
- Consolidar una “Oficina de Datos de Resiliencia Nacional” bajo el futuro Centro Nacional de Ciberseguridad, con mandato claro de:
Definir y mantener el catálogo oficial de indicadores nacionales.
Integrar datos de ENS, NIS2, DORA, CERTs y reguladores.
Publicar informes periódicos de resiliencia (no sólo de amenazas/incidentes).
- Normalizar el reporting de continuidad en operadores esenciales y sector público.
Formularios estándar de incidentes que recojan RTO comprometidos, tiempos reales de restauración, uso de BCP, modo degradado, etc..253
Incorporar estos datos en el IASN y en los informes anuales de ENCS/PNC.161315
- Extender la lógica de ENS a la empresa privada crítica.
Aprovechar la actualización ENS y la futura Ley de Ciberseguridad para alinear controles de continuidad (BIA, BCP, pruebas) con NIS2/DORA, y exigir reportes agregables.7234
- Impulsar ejercicios nacionales de ciber crisis y continuidad multinivel con métricas claras.
Cada ejercicio debería producir KPIs comparables (tiempos de decisión, de notificación, de restauración, calidad de la coordinación) y alimentar el cuadro nacional.613618
- Convertir el banco de preguntas de encuesta en instrumento de diagnóstico periódico.
Aplicado a CCAA, grandes operadores y ministerios, permitiría seguir la evolución de la madurez de BCM/ciber-resiliencia con un coste bajo y una riqueza cualitativa alta.589
- Definir y mantener el catálogo oficial de indicadores nacionales.
- Integrar datos de ENS, NIS2, DORA, CERTs y reguladores.
- Publicar informes periódicos de resiliencia (no sólo de amenazas/incidentes).

- Formularios estándar de incidentes que recojan RTO comprometidos, tiempos reales de restauración, uso de BCP, modo degradado, etc..253
- Incorporar estos datos en el IASN y en los informes anuales de ENCS/PNC.161315
- Aprovechar la actualización ENS y la futura Ley de Ciberseguridad para alinear controles de continuidad (BIA, BCP, pruebas) con NIS2/DORA, y exigir reportes agregables.7234
- Cada ejercicio debería producir KPIs comparables (tiempos de decisión, de notificación, de restauración, calidad de la coordinación) y alimentar el cuadro nacional.613618
- Aplicado a CCAA, grandes operadores y ministerios, permitiría seguir la evolución de la madurez de BCM/ciber-resiliencia con un coste bajo y una riqueza cualitativa alta.589
- “¿Cuánto tarda el país en recuperar sus servicios esenciales tras un ciberincidente grave?”
- “¿Qué porcentaje de nuestra economía depende de proveedores TIC críticos cuya continuidad hemos probado en serio?”
- “¿Cuántas veces al año ensayamos, como país, una gran interrupción digital?”

Cuando esas respuestas puedan darse con indicadores claros, series temporales y comparaciones internacionales, la continuidad de negocio habrá dejado de ser un capítulo técnico para convertirse en una **palanca estratégica de soberanía y competitividad digital**. Y, de paso, dormirán todos — CISOs, DPOs, directores de continuidad y responsables públicos— un poco mejor. O al menos con la conciencia más tranquila.

100646566676869707172737475767778798081828384858687888990919293949596979899